

SECURITY INCIDENT REPORT

IR-2026-0627-001

Multi-Stage Cloud Intrusion — Credential Leak to Lateral Movement

27 June 2026 | 11:14 UTC – 13:44 UTC | Duration: ~2 hours 30 minutes

Classification	CONFIDENTIAL — Restricted to named recipients only
Incident ID	IR-2026-0627-001
Incident Date	27 June 2026
Activity Window	11:14:39 UTC – 13:44:47 UTC (approx. 2 hr 30 min)
Overall Severity	CRITICAL
Incident Status	ACTIVE — Under Investigation
Attack Stages	6 confirmed attack stages
Affected Account	714509059992 (us-east-1)
Primary Threat Actor IP	42.106.176.183 (external)
Compromised Principal	arn:aws:iam::714509059992:user/dev-test
Prepared By	Security Operations Center
Report Date	27 June 2026

1. Executive Summary

On 27 June 2026, AWS account 714509059992 sustained a coordinated six-stage cloud intrusion spanning approximately two and a half hours. The attack chain originated from a misconfigured S3 bucket that exposed IAM credential material to the public internet, and progressed through account reconnaissance, external network scanning, privilege escalation to AdministratorAccess, full-account API enumeration, and internal lateral movement into the private subnet.

The attack was carried out from a single external IP address (42.106.176.183) using credentials belonging to IAM user dev-test. Automated detection and partial remediation was provided by the SecurityMetrics CloudWatch alarm suite and the security-auto-remediate Lambda function. However, the initial credential exposure (Attack 1) had no automated blocking control, which allowed the entire subsequent chain to execute.

By Attack 4, the attacker had achieved full AdministratorAccess to the account. By Attack 6, they had pivoted from the public-facing EC2 instance into the private subnet (10.0.2.240), placing internal databases and services within attack reach. The incident is active and containment actions are outstanding.

#	Time (UTC)	Attack	Technique	Severity
1	11:14:39 UTC	S3 Bucket Public Exposure	T1530 Data from Cloud Storage Object	HIGH
2	11:59:33 UTC	IAM Credential Misuse from External IP	T1078 Valid Accounts	CRITICAL
3	12:36:42 UTC	External Port Scan on EC2	T1046 Network Service Discovery	HIGH
4	12:48:27 UTC	IAM Privilege Escalation	T1098 Account Manipulation	CRITICAL
5	12:58:01 UTC	API Enumeration — Administrative Reconnaissance	T1580 Cloud Infrastructure Discovery	HIGH
6	13:44:47 UTC	Internal Lateral Movement and Port Scan	T1021 Remote Services, T1046 Network Service Discovery	CRITICAL

2. Attack Timeline & Chain of Events

The six attacks form a continuous kill chain. Each stage provided capability or access leveraged directly in the next. The 45-minute gap between Attack 2 (11:59) and Attack 3 (12:36) likely represents attacker dwell time processing reconnaissance output before initiating the network scan.

Time (UTC)	Stage	Method	Chain Impact
11:14:39	S3 Public Exposure	PutBucketPublicAccessBlock + ACL	IAM credentials exposed publicly — root cause of all subsequent attacks
11:59:33	Credential Misuse	ListUsers, DescribeInstances, ListBuckets	Account structure mapped; Network ACL DENY injected by Lambda for IP 42.106.176.183
12:36:42	External Port Scan	High-volume TCP port probing	Open services on public EC2 enumerated; attack surface for foothold identified
12:48:27	Privilege Escalation	AttachUserPolicy → AdministratorAccess	CRITICAL: Full administrative control achieved. All permission boundaries eliminated.
12:58:01	Admin Recon / API Burst	27 cross-service API calls	Complete infrastructure inventory obtained under admin rights
13:44:47	Lateral Movement	Public EC2 → Private subnet pivot	CRITICAL: Private network segment reached (10.0.2.240). Internal services at risk.

3. Detailed Attack Analysis

3.1 Attack 1: S3 Bucket Public Exposure

Timestamp	11:14:39 UTC
Severity	HIGH
MITRE ATT&CK	T1530 — Data from Cloud Storage Object [Collection]
Detection Evidence	AWS Config Rule s3-bucket-public-read-prohibited transitioned to NON_COMPLIANT
Log Evidence	CloudTrail Event ID 2a60ac3d-2f2b-4cb4-891a-b7c923975a79 — PutBucketPublicAccessBlock event on resource test-bucket-simulation-222234573
Root Cause	Block public access was disabled and a credentials file was made publicly accessible via ACL, resulting in credential exposure to the open internet.
Impact	Credential material exposed publicly. Leaked keys used in all subsequent attacks.
Automated Response	Flagged by AWS Config. No active Lambda remediation configured for this misconfiguration. Manual intervention required.
Affected Resource	test-bucket-simulation-222234573

3.2 Attack 2: IAM Credential Misuse from External IP

Timestamp	11:59:33 UTC
Severity	CRITICAL
MITRE ATT&CK	T1078 — Valid Accounts [Initial Access / Defense Evasion]
Detection Evidence	CloudWatch IAMMisuse-Alarm triggered to ALARM state
Log Evidence	CloudTrail logs confirm reconnaissance API calls (ListUsers, DescribeInstances, ListBuckets) originating from external IP 42.106.176.183 using credentials belonging to dev-test
Root Cause	Attacker authenticated using IAM credentials leaked in Attack 1 to perform systematic account reconnaissance.
Impact	Full account reconnaissance completed. Attacker mapped EC2 instances, IAM users, S3 buckets, and account structure.
Automated Response	Lambda function security-auto-remediate triggered — parsed alarm, extracted source IP 42.106.176.183, injected DENY rule into Network ACL. SNS alert dispatched.
Affected Resource	IAM user dev-test Access Key AKIA2MXAPA6MB3PU4ACO

3.3 Attack 3: External Port Scan on EC2

Timestamp	12:36:42 UTC
Severity	HIGH
MITRE ATT&CK	T1046 — Network Service Discovery [Discovery]
Detection Evidence	CloudWatch PortScan-Alarm triggered to ALARM state

Log Evidence	VPC Flow Logs (/aws/vpc/flowlogs) show high-volume connection attempts from external IP 42.106.176.183 probing multiple destination ports on the public-facing EC2 instance
Root Cause	A public-facing EC2 instance exposed an active network footprint to the internet, enabling external port enumeration despite the Network ACL DENY added in Attack 2 response.
Impact	Open ports and services on the public EC2 instance were enumerated, identifying attack surfaces for lateral movement.
Automated Response	Alarm notification delivered via SNS to email. No automated network-level blocking triggered for this alarm.
Affected Resource	Public EC2 instance — public subnet External IP 42.106.176.183

3.4 Attack 4: IAM Privilege Escalation

Timestamp	12:48:27 UTC
Severity	CRITICAL
MITRE ATT&CK	T1098 — Account Manipulation [Persistence / Privilege Escalation]
Detection Evidence	CloudWatch PrivEsc-Alarm triggered to ALARM state
Log Evidence	CloudTrail logs confirm AttachUserPolicy event for user dev-test — AdministratorAccess policy ARN attached, granting full administrative rights
Root Cause	The dev-test user possessed IAM policy-attachment permissions. The attacker exploited this to self-assign AdministratorAccess, achieving full account control.
Impact	CRITICAL: Attacker achieved full administrative access to AWS account 714509059992. All subsequent actions performed with unrestricted permissions.
Automated Response	Lambda function triggered. SNS alert dispatched to email.
Affected Resource	IAM user dev-test Policy: AdministratorAccess

3.5 Attack 5: API Enumeration — Administrative Reconnaissance

Timestamp	12:58:01 UTC
Severity	HIGH
MITRE ATT&CK	T1580 — Cloud Infrastructure Discovery [Discovery]
Detection Evidence	CloudWatch APIBurst-Alarm triggered to ALARM state
Log Evidence	CloudTrail logs confirm a burst of 27 API calls executed by dev-test across multiple services within a short window
Root Cause	Privilege escalation in Attack 4 granted unrestricted permissions, enabling comprehensive account enumeration that was previously gated by IAM policy boundaries.
Impact	Complete infrastructure inventory obtained with admin privileges — EC2, RDS, Lambda, S3, SNS, KMS, and CloudTrail configurations all enumerated.
Automated Response	Lambda function triggered. SNS alert dispatched to email.
Affected Resource	IAM user dev-test (with AdministratorAccess) 27 API calls

3.6 Attack 6: Internal Lateral Movement and Port Scan

Timestamp	13:44:47 UTC
Severity	CRITICAL
MITRE ATT&CK	T1021 — Remote Services [Lateral Movement] T1046 — Network Service Discovery [Discovery]
Detection Evidence	CloudWatch LateralMovement-Alarm transitioned to ALARM state
Log Evidence	VPC Flow Logs (/aws/vpc/flowlogs) show internal traffic from public subnet (10.0.1.206) targeting private subnet (10.0.2.240)
Root Cause	The public-facing EC2 instance was compromised and used as a bridgehead to reach the private network segment. Insufficient network isolation between public and private subnets enabled east-west movement.
Impact	Attacker reached private network segment (10.0.2.240). Internal services and databases previously inaccessible from the internet are now within attack reach.
Automated Response	EventBridge/Lambda pipeline triggered by LateralMovement-Alarm. SNS alert dispatched.
Affected Resource	EC2 10.0.1.206 (public subnet) → 10.0.2.240 (private subnet)

4. MITRE ATT&CK Framework Mapping

The attack chain maps across five MITRE ATT&CK tactics, spanning the full pre-compromise to lateral movement arc of the Enterprise framework.

Attack #	Tactic	Technique & ID	Severity	Automated Response
1	Collection	T1530 — Data from Cloud Storage Object	HIGH	No
2	Initial Access / Defense Evasion	T1078 — Valid Accounts	CRITICAL	Yes — Network ACL DENY injected
3	Discovery	T1046 — Network Service Discovery	HIGH	No — SNS notification only
4	Privilege Escalation / Persistence	T1098 — Account Manipulation	CRITICAL	Yes — Lambda triggered + SNS
5	Discovery	T1580 — Cloud Infrastructure Discovery	HIGH	Yes — Lambda triggered + SNS
6a	Lateral Movement	T1021 — Remote Services	CRITICAL	Yes — EventBridge/Lambda + SNS
6b	Discovery	T1046 — Network Service Discovery	CRITICAL	Yes — EventBridge/Lambda + SNS

MITRE Tactics Observed: Initial Access, Collection, Discovery, Privilege Escalation, Persistence, Defense Evasion, Lateral Movement

5. Indicators of Compromise (IOCs)

IOC Type	Value	Context
IP Address	42.106.176.183	All attacker sessions. External IP. Used in Attacks 2, 3, and 6.
IAM User	dev-test	arn:aws:iam::714509059992:user/dev-test — credentials leaked in Attack 1
Access Key	AKIA2MXAPA6MB3PU4ACO	Long-term key exposed via S3 public ACL. Used across all attack stages.
S3 Bucket	test-bucket-simulation-222234573	Public access enabled via PutBucketPublicAccessBlock. CloudTrail Event: 2a60ac3d-2f2b-4cb4-891a-b7c923975a79
CloudTrail Event	2a60ac3d-2f2b-4cb4-891a-b7c923975a79	PutBucketPublicAccessBlock on test-bucket-simulation-222234573 at 11:14:39
EC2 Host (Pivot)	10.0.1.206	Public subnet EC2 instance used as bridgehead for lateral movement in Attack 6
Internal Target	10.0.2.240	Private subnet host targeted in lateral movement — services/function unknown
IAM Policy	AdministratorAccess	Attached to dev-test in Attack 4 via AttachUserPolicy — grants full account control
VPC Flow Log Path	/aws/vpc/flowlogs	Source for lateral movement and port scan evidence

6. Detection & Response Effectiveness

Attack	Detection Source	Time to Detect	Auto-Remediated?	Coverage Gap
1 — S3 Exposure	AWS Config Rule	At misconfiguration event	NO	No Lambda blocking for public access misconfig
2 — Cred Misuse	IAMMisuse-Alarm	44 min post-exposure	YES — NACL DENY	Recon completed before alarm triggered
3 — Port Scan	PortScan-Alarm	Reactive (post-scan)	NO — SNS only	No automated SG or NACL block on port scan detection
4 — Priv Esc	PrivEsc-Alarm	~11 min post-escalation	PARTIAL — SNS	Lambda triggered but AdministratorAccess not revoked automatically
5 — API Burst	APIBurst-Alarm	~10 min post-burst	PARTIAL — SNS	Lambda triggered; no API throttling or key suspension
6 — Lateral Mvmt	LateralMovement-Alarm	Reactive (post-pivot)	PARTIAL — SNS	No automated subnet isolation or host quarantine

Key Finding: The singular unmitigated gap is Attack 1. A Lambda remediation function for PutBucketPublicAccessBlock / S3 public ACL events would have blocked the credential exposure that seeded the entire attack chain.

7. Immediate Containment Actions Required

#	Priority	Action	Owner	Status
1	IMMEDIATE	Disable IAM user dev-test and revoke access key AKIA2MXAPA6MB3PU4ACO	IAM Admin	OPEN
2	IMMEDIATE	Detach AdministratorAccess policy from dev-test if not already done by Lambda	IAM Admin	OPEN
3	IMMEDIATE	Re-enable block public access on test-bucket-simulation-222234573 and audit contents for additional exposed material	S3 / SecOps	OPEN
4	IMMEDIATE	Isolate EC2 instance 10.0.1.206 (public subnet) — remove from load balancer, restrict Security Group to SecOps IPs only	Network / EC2	OPEN
5	IMMEDIATE	Investigate host 10.0.2.240 (private subnet) — determine if compromise has extended beyond initial lateral movement	SecOps	OPEN
6	HIGH	Verify Network ACL DENY for 42.106.176.183 injected by Lambda is still active and effective	Network	OPEN
7	HIGH	Pull full CloudWatch Logs for security-auto-remediate Lambda — confirm all triggered executions completed without error	SecOps	OPEN
8	HIGH	Rotate all IAM credentials for any user or role that had access to test-bucket-simulation-222234573	IAM Admin	OPEN
9	HIGH	Add Lambda remediation for AWS Config s3-bucket-public-read-prohibited — auto-reblock and alert on trigger	SecOps / DevOps	OPEN
10	MEDIUM	Implement subnet-level micro-segmentation or additional Security Group rules between public (10.0.1.0/24) and private (10.0.2.0/24) subnets	Network	OPEN
11	MEDIUM	Enforce MFA on all IAM users — dev-test sessions show mfaAuthenticated: false	IAM Admin	OPEN
12	MEDIUM	Interview or escalate regarding dev-test user account holder — determine insider threat vs. phished credentials	HR / Legal	OPEN

8. Systemic Gaps & Recommendations

8.1 Root Cause: Unguarded S3 Public Access

The entire attack chain is traceable to a single unmitigated misconfiguration. Block public access being disabled on test-bucket-simulation-222234573 and credentials stored in that bucket without encryption or secrets management constitutes a fundamental security failure. A test bucket should never contain live IAM credentials. Implement AWS Secrets Manager or SSM Parameter Store for all credential material immediately.

8.2 Lambda Remediation Coverage Gap

The security-auto-remediate Lambda responded correctly to IAMMisuse, PrivEsc, APIBurst, and LateralMovement alarms. However, it had no coverage for S3 public access events (Config-based). Adding a Config rule remediation Lambda for s3-bucket-public-read-prohibited would have blocked credential exposure at 11:14 and prevented all five subsequent attacks.

8.3 Privilege Escalation Not Fully Automated

When PrivEsc-Alarm fired at 12:48, the Lambda function triggered but did not automatically revoke the AdministratorAccess policy or suspend the user. Automated privilege revocation on confirmed escalation events should be implemented, with a manual re-authorization process to restore access.

8.4 Insufficient Network Isolation

The fact that the compromised public EC2 (10.0.1.206) could directly reach the private subnet (10.0.2.240) indicates inadequate network segmentation. Public and private subnet tiers should not have permissive Security Group rules between them. Implement a least-privilege SG policy requiring all traffic to pass through an intermediary (NAT, ALB, or inspection layer).

8.5 No Automated Response for Port Scan Detection

PortScan-Alarm fired at 12:36 but triggered only an SNS notification. The attacker was not blocked at the network layer by this alarm. Implement an automated Security Group or NACL update to block the source IP when PortScan-Alarm transitions to ALARM, mirroring what IAMMisuse-Alarm triggers.

9. Report Authorization & Sign-Off

Role	Name / Signature	Date
Incident Lead		
CISO / Security Manager		
Legal / Compliance		
HR Representative		

This report contains confidential security incident information generated from live AWS CloudTrail, CloudWatch, VPC Flow Logs, and AWS Config evidence. Distribution is restricted to named recipients and authorized security personnel only. Unauthorized disclosure may compromise active investigation, legal proceedings, or ongoing remediation efforts.